CRISC Domain D - 100 More Impossible Hard Questions

Information Technology and Security - Expert Level Part 2

CRISC Mastery Series

October 21, 2026

Warning

Extreme Difficulty

Domain D is technical but the exam tests judgment, not trivia.
Every option will look plausible.
Think like a risk practitioner advising on technology, not a technician.

Outline

1. 1. Enterprise Architecture
2. 2. IT Operations and Change Management
3. 3. Enterprise Resiliency
4. 4. Data Lifecycle Management
5. 5. SDLC and Emerging Technologies
6. 6. Information Security Principles

Q101: Architecture Governance Board

Question

An architecture review board rejects a project because it violates a principle. The project sponsor appeals. What is the BEST governance path?

A. The sponsor proceeds

B. The board decision stands unless escalated through defined exception governance

C. The board is dissolved

D. The vendor decides

Q101: Explanation

Correct Answer: B

Exceptions follow governance:

- Boards enforce principles
- Exceptions require escalation and approval
- Proceeding undermines the board

Critical Trap

Architecture exceptions need governance, not bypass.

Q102: TOGAF ADM Purpose

Question

What is the purpose of the TOGAF Architecture Development Method?

- A Marketing plan
- B Structured method for developing and managing architecture
- C Network monitoring
- D HR planning

Q102: Explanation

Correct Answer: B

ADM structures architecture work:

- Provides phases from vision to maintenance
- Iterative and adaptable
- Aligns architecture to strategy

Critical Trap

ADM is the method, not a framework replacement.

Q103: Architecture Views

Question

Why does EA use multiple views?

A. To confuse stakeholders

B. To communicate to different audiences (business, data, application, technology)

C. To increase costs

D. To hide issues

Q103: Explanation

Correct Answer: B

Views match audiences:

- Different views for different concerns
- Business view supports executives
- Technology view supports engineers

Critical Trap

Views exist to communicate, not to obscure.

Q104: EA Metrics

Question

Which metric BEST reflects EA value?

A. Number of diagrams produced
B. Reduction in duplication and improved alignment with strategy
C. Meeting attendance
D. Vendor count

Q104: Explanation

Correct Answer: B

EA value is alignment and efficiency:

- Reduced duplication saves cost
- Alignment protects value
- Diagrams are outputs, not outcomes

Critical Trap

Diagrams are not the value; outcomes are.

Q105: Reference Architectures

Question

What is the MAIN benefit of a reference architecture?

A. Avoids standards
B. Provides a reusable pattern for consistent designs
C. Faster meetings
D. Larger budgets

Q105: Explanation

Correct Answer: B

Reference architectures reuse patterns:

- Consistent design accelerates delivery
- Reduces rework
- Improves quality

Critical Trap

Reference architectures are patterns, not mandates.

Q106: Architecture Principle Example

Question

Which is a valid architecture principle?

A. All vendors must be fired
B. Data is a shared enterprise asset with controlled access
C. Only one server is allowed
D. Ignore all audits

Q106: Explanation

Correct Answer: B

Principles must guide decisions:

- Data as shared asset guides access design
- Principles are directional, not operational rules
- Extreme statements are not principles

Critical Trap

Principles guide, not ban.

Q107: Architecture Repository

Question

What is the MAIN purpose of an architecture repository?

A. Store backups

B. Centralize architecture assets, standards, and decisions

C. Track HR records

D. Manage payroll

Q107: Explanation

Correct Answer: B

Repository preserves architecture knowledge:

- Central access to assets
- Supports reuse and governance
- Prevents lost knowledge

Critical Trap

Repository is a knowledge asset, not a backup.

Q108: EA and Business Strategy

Question

Which of the following signals that EA is aligned to business strategy?

A. IT chooses tools without business input
B. Roadmaps reflect business objectives and priorities
C. Only vendors influence architecture
D. Architecture is independent of strategy

Q108: Explanation

Correct Answer: B

Alignment shows in roadmaps:

- Roadmaps translate strategy into action
- Business objectives drive technology
- Isolation signals misalignment

Critical Trap

Alignment is proven by roadmaps, not documents.

Q109: Architecture Change Management

Question

What does architecture change management do?

- A Ignores changes
- B Governs changes to the architecture and maintains alignment
- C Backs up files
- D Manages emails

Q109: Explanation

Correct Answer: B

Change keeps architecture aligned:

- Governs architecture change
- Prevents drift
- Maintains strategy alignment

Critical Trap

Architecture changes need governance.

Q110: EA Maturity

Question

What does high EA maturity usually indicate?

- A More drawings
- B Consistent, strategy-aligned technology decisions across the enterprise
- C Larger budgets
- D Fewer audits

Q110: Explanation

Correct Answer: B

High maturity is alignment at scale:

- Consistent decisions
- Strategy-driven technology
- Reduced duplication

Critical Trap

Maturity is about consistency, not documents.

Q111: Change Management KPIs

Question

Which KPI BEST measures change management effectiveness?

A. Number of meetings

B. Percentage of changes with successful outcomes and no unplanned downtime

C. Number of tickets closed

D. Budget spent

Q111: Explanation

Correct Answer: B

Change success rate is the KPI:

- Successful changes indicate control
- Unplanned downtime shows failures
- Meetings and budgets are inputs

Critical Trap

Success rate, not volume, measures effectiveness.

Q112: Change Freeze

Question

What is the purpose of a change freeze?

A. To block all progress
B. To reduce risk during critical business periods
C. To save money
D. To punish developers

Q112: Explanation

Correct Answer: B

Freeze protects high-risk periods:

- Financial close, holidays, peak seasons
- Reduces risk of disruption
- Emergency changes may still be approved

Critical Trap

Freeze is a risk control, not a block on progress.

Q113: Change vs Release

Question

What is the MAIN distinction between change management and release management?

A. They are the same
B. Change governs individual changes; release coordinates deployment packages
C. Release is only for hardware
D. Change is only for software

Q113: Explanation

Correct Answer: B

Change governs; release coordinates:

- Change evaluates and approves
- Release coordinates deployment
- Both reduce risk

Critical Trap

Change approves; release deploys.

Q114: Root Cause Analysis

Question

Which tool BEST supports root cause analysis?

A. Gantt chart
B. Ishikawa (fishbone) diagram
C. Org chart
D. Budget spreadsheet

Q114: Explanation

Correct Answer: B

Fishbone finds causes:

- Categorizes potential causes
- Structures problem-solving
- Supports problem management

Critical Trap

Fishbone is for causes; Gantt is for scheduling.

Q115: ITIL Service Value

Question

What does ITIL focus on in IT operations?

A. Bypassing governance

B. Delivering value through IT services aligned to business needs

C. Only writing code

D. Only managing hardware

Q115: Explanation

Correct Answer: B

ITIL is about service value:

- Services aligned to business
- Value realized through outcomes
- Continuous improvement

Critical Trap

ITIL is about value, not just process.

Q116: Incident Severity

Question

Which factor should MOST drive incident severity classification?

A. Number of people who reported it
B. Business impact and urgency
C. Age of the ticket
D. Vendor preference

Q116: Explanation

Correct Answer: B

Impact and urgency drive severity:

- Severity reflects business impact
- Urgency reflects time sensitivity
- Reports and age are secondary

Critical Trap

Severity is impact plus urgency, not ticket count.

Q117: Configuration Item

Question

What is a configuration item in ITIL terms?

- A. A budget line
- B. Any component under configuration management that is needed to deliver a service
- C. A user
- D. A vendor

Q117: Explanation

Correct Answer: B

CIs are managed components:

- Hardware, software, documentation
- Managed through the CMDB
- Enable impact analysis

Critical Trap

CIs are managed components, not budgets.

Q118: CMDB Purpose

Question

What is the MAIN purpose of a Configuration Management Database?

A. Store employee records

B. Maintain relationships between configuration items and support impact analysis

C. Manage budgets

D. Track marketing

Q118: Explanation

Correct Answer: B

CMDB maps relationships:

- Supports impact analysis
- Reveals dependencies
- Guides change risk

Critical Trap

CMDB is about relationships, not records.

Q119: Service Level Agreement

Question

What is the primary purpose of a Service Level Agreement?

- A Define penalties only
- B Define agreed service levels and expectations between provider and customer
- C Replace contracts
- D Avoid monitoring

Q119: Explanation

Correct Answer: B

SLA defines expectations:

- Service levels and targets
- Measurable expectations
- Supports governance

Critical Trap

SLA is about expectations, not just penalties.

Q120: Operational Metrics

Question

Which metric BEST reflects operational stability?

A. Number of meetings
B. Mean time to resolve incidents and system uptime
C. Training slides
D. Vendor discounts

Q120: Explanation

Correct Answer: B

Stability is MTTR and uptime:

- MTTR shows response effectiveness
- Uptime shows availability
- Both reflect operations

Critical Trap

Stability is uptime and resolution, not process volume.

Q121: BIA vs DR

Question

What is the role of a Business Impact Analysis in disaster recovery?

- A Unrelated
- B BIA defines critical processes and recovery objectives that DR implements
- C DR replaces BIA
- D BIA replaces BC

Q121: Explanation

Correct Answer: B

BIA informs DR:

- BIA defines priorities and RTO/RPO
- DR implements recovery
- BIA is the input, DR is the execution

Critical Trap

BIA comes before DR; DR implements BIA.

Q122: RTO Realism

Question

An RTO of 5 minutes is proposed for a system with hourly backups. What is the issue?

A. No issue
B. RPO does not support RTO
C. RTO is too long
D. Backups are too frequent

Q122: Explanation

Correct Answer: B

RPO must support RTO:

- Hourly backups cannot restore quickly
- RTO must match recovery technology
- Realistic objectives matter

Critical Trap

RTO must be realistic against backup and recovery capability.

Q123: Cold vs Warm vs Hot Site

Question

Which site type offers the fastest recovery?

A. Cold site
B. Warm site
C. Hot site
D. No site

Q123: Explanation

Correct Answer: C

Hot site is fastest:

- Fully operational duplicate
- Immediate failover
- Highest cost

Critical Trap

Hot site is fastest, costliest.

Q124: Cold Site Use

Question

When is a cold site MOST appropriate?

A. Mission-critical 24/7 systems

B. Low-criticality systems with long tolerable downtime

C. Trading systems

D. Always

Q124: Explanation

Correct Answer: B

Cold sites suit long RTOs:

- No hardware pre-installed
- Requires time to build
- Suitable for low criticality

Critical Trap

Cold sites have long recovery times.

Q125: Backup vs Replication

Question

What is the MAIN difference between backup and replication?

- A. They are identical
- B. Backup copies data periodically; replication mirrors data continuously or near-continuously
- C. Backup is continuous; replication is periodic
- D. Both are manual

Q125: Explanation

Correct Answer: B

Backup periodic; replication continuous:

- Backup creates recovery points
- Replication maintains mirrors
- Both reduce recovery time

Critical Trap

Backup is periodic; replication mirrors.

Q126: Ransomware Recovery

Question

Which is MOST important for ransomware recovery?

A. Number of antivirus tools
B. Immutable, offline backups and tested restore capability
C. Faster email
D. More vendors

Q126: Explanation

Correct Answer: B

Immutable backups protect against ransomware:

- Online backups can be encrypted
- Immutable and offline backups stay clean
- Restore testing is critical

Critical Trap

Ransomware encrypts connected backups. Immutable backups matter.

Q127: Recovery Prioritization

Question

Which system should be restored FIRST after a disaster?

A. Lowest-cost system

B. System with the smallest RTO critical to business continuity

C. Oldest system

D. Newest system

Q127: Explanation

Correct Answer: B

Priority follows RTO and criticality:

- Shortest RTO first
- Critical business processes
- Recovery sequence matters

Critical Trap

Recovery priority = criticality and RTO, not cost or age.

Q128: BCP Communication

Question

Which is essential for BCP communication during a disruption?

- A Marketing brochures
- B Predefined channels, roles, and templates for internal and external stakeholders
- C Only internal chat
- D Only email

Q128: Explanation

Correct Answer: B

Preplanned communication saves time:

- Defined channels
- Named roles
- Ready templates

Critical Trap

Communication must be planned, not improvised.

Q129: BCP Exercise Types

Question

Which exercise type provides the HIGHEST confidence at the LOWEST cost?

A. Full failover with real services
B. Tabletop exercise with key stakeholders
C. Ignoring the plan
D. Adding more tools

Q129: Explanation

Correct Answer: B

Tabletop balances cost and value:

- Low cost
- Reveals gaps in roles and communications
- Prepares for full tests

Critical Trap

Tabletop = highest value at low cost.

Q130: BCP Update Triggers

Question

Which event should trigger a BCP update?

A. Staff birthday
B. Major business or technology change
C. Vendor price change
D. Office decoration

Q130: Explanation

Correct Answer: B

Significant change triggers review:

- Architecture or process changes
- Affects RTO/RPO
- Keeps BCP current

Critical Trap

BCP updates follow significant change.

Q131: Data Classification Levels

Question

Which is a typical data classification set?

A. Fast, slow, medium
B. Public, internal, confidential, restricted
C. Red, green, blue
D. Old, new, older

Q131: Explanation

Correct Answer: B

Public, internal, confidential, restricted:

- Common classification levels
- Sensitivity determines controls
- Aligns with regulations

Critical Trap

Classification is sensitivity-based, not time-based.

Q132: Data Ownership vs Custody

Question

Who decides who can access specific data?

A. The custodian
B. The data owner
C. The user
D. The vendor

Q132: Explanation

Correct Answer: B

Data owners authorize access:

- Owners determine access rights
- Custodians implement controls
- Users consume data

Critical Trap

Owners authorize; custodians implement.

Q133: Retention vs Legal Hold

Question

A retention schedule says destroy after 7 years. A legal hold is in place. What applies?

A. Destroy per schedule
B. Legal hold overrides the retention schedule
C. Ignore both
D. Destroy immediately

Q133: Explanation

Correct Answer: B

Legal hold overrides:

- Preserve during hold
- Destruction during hold is a violation
- Release the hold when cleared

Critical Trap

Legal holds suspend retention rules.

Q134: DLP Enforcement

Question

Which data classification MOST benefits from DLP enforcement?

A. Public data
B. Highly confidential data
C. Marketing brochures
D. Training materials

Q134: Explanation

Correct Answer: B

DLP protects sensitive data:

- Confidential and restricted classes
- DLP prevents leakage
- Public data has less need

Critical Trap

DLP is for high-sensitivity data.

Q135: Data Lifecycle Creation

Question

At which lifecycle stage should classification occur?

A. Creation
B. Archiving
C. Destruction
D. Only after a year

Q135: Explanation

Correct Answer: A

Classify at creation:

- Classify early to enforce controls
- Late classification is often forgotten
- Creation is the start of protection

Critical Trap

Classify early, protect early.

Q136: Data Minimization GDPR

Question

Which principle aligns with GDPR data minimization?

- A Collect everything
- B Collect only data needed for stated purposes
- C Retain data forever
- D Ignore privacy

Q136: Explanation

Correct Answer: B

Collect only what is needed:

- Reduces exposure
- Supports privacy
- Improves compliance

Critical Trap

Data minimization = need-to-know collection.

Q137: Data Destruction Certificate

Question

Why is a Certificate of Destruction important?

A. Marketing

B. Provides documented evidence that data was securely destroyed

C. Tax filing

D. Vendor discounts

Q137: Explanation

Correct Answer: B

Evidence matters:

- Documents compliant destruction
- Supports audit
- Protects legally

Critical Trap

Destroyed without evidence is not defensible.

Q138: Cloud Data Location

Question

Why is data location important for cloud-stored data?

- A Latency only
- B Legal jurisdiction and data residency requirements
- C Vendor pricing
- D Logo placement

Q138: Explanation

Correct Answer: B

Location determines legal exposure:

- Data residency laws
- Jurisdiction impacts regulator access
- Compliance risks

Critical Trap

Data location is a legal concern.

Q139: Data Subject Request

Question

What should an organization do FIRST when receiving a data subject access request?

A. Delete data

B. Verify the identity of the requester

C. Forward to marketing

D. Ignore it

Q139: Explanation

Correct Answer: B

Verify identity first:

- Prevents unauthorized disclosure
- Ensures right person
- Then fulfill the request

Critical Trap

Verify identity before responding to any DSR.

Q140: Archival Encryption

Question

Why should archived data remain encrypted?

A. To save cost

B. To protect against exposure if storage is compromised

C. To speed up retrieval

D. To avoid retention

Q140: Explanation

Correct Answer: B

Archived data remains at risk:

- Long-term storage
- Sensitive data persists
- Encryption reduces exposure

Critical Trap

Archived data still needs protection.

Q141: Waterfall vs Agile Risk

Question

Which model has GREATER change-related risk?

A. Waterfall
B. Agile
C. Both equal
D. Neither

Q141: Explanation

Correct Answer: B

Agile changes rapidly:

- Agile changes rapidly
- Continuous testing is essential
- Waterfall changes are costly

Critical Trap

Agile risk = change management.

Q142: Secure Code Review

Question

What is the PRIMARY benefit of secure code review?

- A Faster delivery
- B Early detection of vulnerabilities before release
- C Lower storage
- D More features

Q142: Explanation

Correct Answer: B

Early detection reduces cost:

- Defects cheaper to fix early
- Security reviewed before exposure
- Complements testing

Critical Trap

Early detection is cheaper than late repair.

Q143: Dependency Scanning

Question

Why is dependency scanning critical in modern SDLC?

A. Vendors require it
B. Third-party libraries introduce vulnerabilities
C. It speeds deployment
D. It reduces costs

Q143: Explanation

Correct Answer: B

Dependencies introduce risk:

- Open-source libraries can have CVEs
- Regular scanning detects them
- Reduces supply chain risk

Critical Trap

Dependency risk is a growing threat vector.

Q144: Container Security

Question

Which security control is MOST important for containerized workloads?

A. Antivirus on hosts
B. Image scanning and runtime monitoring
C. Only firewalls
D. Only encryption

Q144: Explanation

Correct Answer: B

Image scanning plus runtime:

- Scans for vulnerable images
- Runtime detection
- Covers container lifecycle

Critical Trap

Containers need image and runtime controls.

Q145: Cloud Shared Responsibility

Question

What does the shared responsibility model mean in cloud?

- A Provider responsible for everything
- B Provider secures infrastructure; customer secures configuration, data, and identity
- C Customer responsible for everything
- D No responsibility

Q145: Explanation

Correct Answer: B

Security is shared:

- Provider secures physical and hypervisor
- Customer secures data and configuration
- Misunderstanding causes breaches

Critical Trap

Cloud security is shared, not delegated.

Q146: SaaS Tenant Isolation

Question

Why is SaaS tenant isolation important?

A. Performance only

B. Prevents data leakage between customers

C. Reduces cost

D. Simplifies audits

Q146: Explanation

Correct Answer: B

Isolation prevents cross-tenant leakage:

- Multi-tenancy risk
- Isolation required
- Verify in contracts

Critical Trap

Tenant isolation is a critical SaaS control.

Q147: Quantum Safe Cryptography

Question

What should organizations do about post-quantum cryptography?

- A Wait until quantum computers exist
- B Plan migration to quantum-safe algorithms
- C Ignore
- D Use only symmetric

Q147: Explanation

Correct Answer: B

Plan migration now:

- Harvest-now-decrypt-later risk
- Post-quantum algorithms available
- Migration takes years

Critical Trap

Quantum migration must start early.

Q148: IoT Segmentation

Question

Why segment IoT devices from corporate networks?

A. Better performance
B. Limits blast radius if devices are compromised
C. Reduces cost
D. Simpler backups

Q148: Explanation

Correct Answer: B

Segmentation limits damage:

- IoT often has weak security
- Segmentation contains compromise
- Reduces lateral movement

Critical Trap

IoT segmentation is a mitigation, not a fix.

Q149: AI Explainability

Question

Why is AI explainability important for governance?

A. Faster training

B. Enables oversight, audit, and accountability

C. Cheaper GPUs

D. Marketing value

Q149: Explanation

Correct Answer: B

Explainability enables governance:

- Decisions can be audited
- Bias can be detected
- Accountability supported

Critical Trap

Opaque AI cannot be governed.

Q150: Smart Contract Risk

Question

What is a key governance risk with smart contracts?

A. Slow execution

B. Bugs cannot be easily corrected once deployed

C. Too many users

D. High cost

Q150: Explanation

Correct Answer: B

Immutability has consequences:

- Deployed contracts immutable
- Bugs persist
- Requires thorough testing before deployment

Critical Trap

Smart contract bugs are permanent.

Q151: IAAA Accountability

Question

Which principle logs and monitors what users did?

A. Identification
B. Authentication
C. Authorization
D. Accountability

Q151: Explanation

Correct Answer: D

Accountability tracks actions:

- Logs record activity
- Supports investigation
- Non-repudiation support

Critical Trap

Accountability = logging and monitoring.

Q152: Authorization Definition

Question

Authorization defines:

A. Who you are
B. What you can do
C. How you authenticate
D. Where you log in

Q152: Explanation

Correct Answer: B

Authorization is permission:

- Determines actions allowed
- Enforced through access control
- Post-authentication decision

Critical Trap

Authorization = what you can do.

Q153: Hashing Password Storage

Question

Why store passwords as hashes instead of encryption?

A. Faster

B. Hashes cannot be reversed to plaintext

C. Cheaper

D. Shorter

Q153: Explanation

Correct Answer: B

Hashes are one-way:

- Reversal infeasible
- Even if breached, plaintext is not exposed
- Salt adds further protection

Critical Trap

Hashing is one-way; encryption is reversible.

Q154: Salt Purpose

Question

What is the purpose of salting password hashes?

A. Speeds up login

B. Prevents identical passwords from producing the same hash

C. Reduces storage

D. Simplifies resets

Q154: Explanation

Correct Answer: B

Salt makes hashes unique:

- Different salt per password
- Defeats rainbow tables
- Strengthens storage

Critical Trap

Salting defeats precomputed attacks.

Q155: TLS Purpose

Question

What does TLS provide in transit?

- A Storage encryption only
- B Confidentiality and integrity over the network
- C Antivirus
- D Backups

Q155: Explanation

Correct Answer: B

TLS protects transit:

- Encrypts traffic
- Verifies integrity
- Certificate-based trust

Critical Trap

TLS is transit protection, not storage.

Q156: Firewall Purpose

Question

What is the PRIMARY purpose of a firewall?

A. Encrypt traffic
B. Enforce network policy on traffic
C. Back up data
D. Detect malware

Q156: Explanation

Correct Answer: B

Firewalls enforce policy:

- Allow or deny traffic
- Rule-based
- Complements other controls

Critical Trap

Firewalls enforce policy; they do not encrypt.

Q157: IDS vs IPS

Question

Which is passive and which is active?

A. IDS passive; IPS active
B. IDS active; IPS passive
C. Both active
D. Both passive

Q157: Explanation

Correct Answer: A

IDS detects; IPS blocks:

- IDS detects only
- IPS detects and blocks
- Choose based on requirements

Critical Trap

IDS detects; IPS blocks.

Q158: WAF Purpose

Question

What does a Web Application Firewall primarily do?

- A Encrypt web content
- B Filter HTTP traffic to protect web apps from common attacks
- C Back up websites
- D Manage DNS

Q158: Explanation

Correct Answer: B

WAF filters HTTP:

- Protects against OWASP Top 10
- Complements firewalls
- Layer 7 filtering

Critical Trap

WAF is layer 7 web protection.

Q159: Zero Trust Identity

Question

What identity principle is central to Zero Trust?

A. Trust all internal users
B. Verify every access request regardless of location
C. Use only passwords
D. Trust all vendors

Q159: Explanation

Correct Answer: B

Verify every request:

- Identity and context
- Continuous verification
- No implicit trust

Critical Trap

Zero Trust = verify every access, every time.

Q160: MFA Fatigue Attack

Question

What is MFA fatigue and how is it mitigated?

A. Users forget passwords; reset them

B. Attackers spam MFA prompts; mitigate with number matching and rate limits

C. MFA never fails

D. MFA is unused

Q160: Explanation

Correct Answer: B

Spamming prompts tricks users:

- Attackers flood MFA prompts
- Users approve by accident
- Number matching mitigates

Critical Trap

MFA fatigue attacks exploit user fatigue.

Q161: Identity Provider Compromise

Question

What is the PRIMARY risk if the identity provider is compromised?

A. Slower logins

B. Attacker can impersonate users and access resources

C. Loss of backups

D. Slower printing

Q161: Explanation

Correct Answer: B

IdP compromise is catastrophic:

- Central trust point
- Attackers can impersonate users
- Protect with MFA, monitoring, least privilege

Critical Trap

IdP is a high-value target.

Q162: Cloud IAM Best Practice

Question

What is a best practice for cloud IAM?

A. Use root account daily

B. Use least privilege, MFA, and role-based access

C. Share admin credentials

D. Disable logging

Q162: Explanation

Correct Answer: B

Least privilege, MFA, RBAC:

- Root account should not be used daily
- Least privilege limits damage
- Logging is essential

Critical Trap

Cloud IAM requires discipline, not convenience.

Q163: Data Residency Risk

Question

What risk does storing data in a foreign cloud region introduce?

A. Only latency
B. Legal jurisdiction and regulatory requirements
C. Slower backups
D. Higher cost only

Q163: Explanation

Correct Answer: B

Legal exposure follows data:

- Different jurisdictions
- Data residency rules
- Regulator access varies

Critical Trap

Data location brings legal exposure.

Q164: Confidential Computing

Question

What does confidential computing protect?

A. Only network traffic
B. Data in use inside trusted execution environments
C. Only backups
D. Only usernames

Q164: Explanation

Correct Answer: B

Protects data in use:

- Trusted execution environments
- Protects from host-level exposure
- Complements encryption at rest and in transit

Critical Trap

Confidential computing = data in use.

Q165: Privileged Access Management

Question

What is the main goal of Privileged Access Management?

A. Give everyone admin access

B. Control, monitor, and audit use of privileged accounts

C. Remove all admins

D. Avoid logging

Q165: Explanation

Correct Answer: B

PAM controls admin access:

- Vault credentials
- Session monitoring
- Approval workflows

Critical Trap

PAM protects the keys to the kingdom.

Q166: Security Awareness Metrics

Question

Which metric BEST shows security awareness effectiveness?

- A Completion rate
- B Reduction in successful phishing clicks and increase in reported phishing
- C Number of slides
- D Training hours

Q166: Explanation

Correct Answer: B

Behavior change matters:

- Behavior change matters
- Completion is activity
- Reports and click rates reflect behavior

Critical Trap

Behavior metrics matter more than completion.

Q167: Insider Threat Indicators

Question

Which is a red flag for insider threat?

A. Timely access requests

B. Unusual access patterns, mass downloads, or access near resignation

C. Regular training completion

D. Using MFA

Q167: Explanation

Correct Answer: B

Unusual patterns are red flags:

- Mass data access
- Odd hours
- Access after notice

Critical Trap

Insider threats show behavioral anomalies.

Q168: Third-Party Breach Risk

Question

When a third party suffers a breach of your data, who is regulated?

A. Only the third party
B. Your organization as data controller
C. Only the regulator
D. No one

Q168: Explanation

Correct Answer: B

Controllers remain regulated:

- You are responsible to regulators
- Third parties act on your behalf
- Contracts and oversight matter

Critical Trap

Outsourcing does not transfer regulatory accountability.

Q169: Data Breach Root Cause

Question

Which is a common root cause of data breaches?

A. Strong MFA everywhere
B. Misconfiguration and weak access management
C. Frequent training
D. Regular audits

Q169: Explanation

Correct Answer: B

Misconfigurations and access weaknesses:

- Common breach causes
- Configuration management matters
- Access reviews reduce risk

Critical Trap

Misconfiguration is a top breach cause.

Q170: Ransomware Defenses

Question

Which combination BEST defends against ransomware?

A. One antivirus tool

B. Backups, segmentation, patching, email filtering, user training, and immutable copies

C. Only MFA

D. Only firewalls

Q170: Explanation

Correct Answer: B

Ransomware defense is layered:

- Backups for recovery
- Segmentation limits spread
- Patching closes entry points
- Training prevents initial access

Critical Trap

Ransomware defense is layered, not a single tool.

Q171: Patch vs Configuration

Question

Which scenario is a PATCHING issue rather than a CONFIGURATION issue?

A. Firewall rule missing
B. Known CVE unfixed on a server
C. Weak password policy
D. Shared admin account

Q171: Explanation

Correct Answer: B

Unfixed CVE is a patch gap:

- Known vulnerability remains
- Patch management addresses it
- Configuration issues are settings

Critical Trap

CVEs are patch issues; settings are configuration issues.

Q172: Vulnerability Prioritization

Question

Which factor MOST improves vulnerability prioritization?

A. Alphabetical order

B. Business criticality of the asset and exploit availability

C. Age of the vulnerability

D. Number of users

Q172: Explanation

Correct Answer: B

Criticality and exploit availability:

- Criticality drives impact
- Exploit availability drives likelihood
- Combine both

Critical Trap

Prioritize by business criticality and exploit availability.

Q173: CVSS Limitations

Question

What is a limitation of CVSS scoring?

A. It captures business context

B. It does not capture business context, only technical severity

C. It replaces prioritization

D. It measures training

Q173: Explanation

Correct Answer: B

CVSS is technical severity:

- No asset criticality context
- Combine with business impact
- Use as one input

Critical Trap

CVSS alone is incomplete. Add business context.

Q174: Pen Test Rules of Engagement

Question

What must rules of engagement define before a penetration test?

- A Only costs
- B Scope, timing, escalation paths, and permitted techniques
- C Only usernames
- D Only vendor names

Q174: Explanation

Correct Answer: B

RoE protects everyone:

- Scope prevents collateral damage
- Timing protects peak hours
- Escalation enables safe handling

Critical Trap

Rules of engagement prevent chaos during pen tests.

Q175: SIEM Purpose

Question

What is the primary purpose of a SIEM system?

A. Encrypt data

B. Correlate security events and alert on threats

C. Back up files

D. Manage HR

Q175: Explanation

Correct Answer: B

SIEM correlates and alerts:

- Aggregates logs
- Correlates events
- Alerts analysts

Critical Trap

SIEM correlates and alerts, not just stores logs.

Q176: SOC Role

Question

What does a Security Operations Center primarily do?

A. Marketing

B. Monitor, detect, and respond to security incidents

C. Manage HR

D. Sell products

Q176: Explanation

Correct Answer: B

SOC monitors and responds:

- Detect threats
- Analyze alerts
- Respond to incidents

Critical Trap

SOC is about monitoring and response.

Q177: Threat Hunting vs Monitoring

Question

What is threat hunting?

A. Waiting for alerts

B. Proactively searching for hidden threats not caught by detection

C. Buying tools

D. Ignoring alerts

Q177: Explanation

Correct Answer: B

Hunting is proactive:

- Hypothesis-driven investigation
- Goes beyond alerts
- Finds stealthy attackers

Critical Trap

Hunting is proactive; monitoring is reactive.

Q178: Threat Intelligence

Question

What is threat intelligence used for?

A. Storing data

B. Understanding adversary tactics, techniques, and indicators

C. Measuring training

D. Computing budgets

Q178: Explanation

Correct Answer: B

Threat intel guides defenses:

- Informs defenses
- Prioritizes patching
- Improves detection

Critical Trap

Threat intel guides defenses and prioritization.

Q179: Incident Response Communications

Question

Why is incident communications planning important?

A. Marketing

B. Provides clear, timely information to stakeholders during an incident

C. Reduces cost

D. Avoids escalation

Q179: Explanation

Correct Answer: B

Communication is part of IR:

- Prevents confusion
- Supports trust
- Protects reputation

Critical Trap

Communication is part of IR, not an afterthought.

Q180: Post-Incident Review

Question

What is the primary purpose of a post-incident review?

A. Assign blame

B. Identify lessons and improve future response

C. Close tickets

D. Reduce budgets

Q180: Explanation

Correct Answer: B

Learn, not blame:

- Root causes
- Lessons learned
- Continuous improvement

Critical Trap

Post-incident reviews are for learning, not blame.

Q181: Privacy Impact Assessment

Question

When should a Privacy Impact Assessment be conducted?

A. After a breach
B. Before implementing new processing that may affect privacy
C. Only at year-end
D. Never

Q181: Explanation

Correct Answer: B

PIA before processing:

- Early assessment
- Identifies privacy risks
- Shapes design

Critical Trap

PIAs are done before processing, not after.

Q182: DPO Role

Question

What is the primary role of a Data Protection Officer?

A. Marketing

B. Advise on GDPR compliance and monitor compliance

C. Manage IT

D. Sell products

Q182: Explanation

Correct Answer: B

DPO advises and monitors:

- Advises on compliance
- Monitors GDPR compliance
- Point of contact for regulators

Critical Trap

DPO advises and monitors, not operates.

Q183: Cross-Border Data Flow

Question

What is required for lawful cross-border data transfer from EU?

- A Nothing
- B Valid legal mechanism such as adequacy decision or SCCs
- C Only consent
- D Email confirmation

Q183: Explanation

Correct Answer: B

Legal mechanisms required:

- Adequacy decision
- Standard Contractual Clauses
- Binding Corporate Rules

Critical Trap

Cross-border transfers need legal mechanisms.

Q184: Breach Notification to Individuals

Question

When must individuals be notified of a breach under GDPR?

A. Always
B. When the breach poses high risk to their rights and freedoms
C. Never
D. Only at year-end

Q184: Explanation

Correct Answer: B

High-risk threshold:

- High-risk threshold
- Clear communication
- Support measures

Critical Trap

Individual notification depends on risk severity.

Q185: HIPAA PHI Definition

Question

What is PHI?

A. Public Health Information

B. Protected Health Information, any information about health status linked to an individual

C. Personal Hiring Information

D. Private Internet

Q185: Explanation

Correct Answer: B

PHI = health data plus identifier:

- Health information linked to individual
- Protected by HIPAA
- Broad definition

Critical Trap

PHI is health data plus identifier.

Q186: PCI DSS Scope

Question

What does PCI DSS cover?

A. Employee records
B. Systems that store, process, or transmit cardholder data
C. Marketing data
D. Office supplies

Q186: Explanation

Correct Answer: B

Cardholder data environment:

- Cardholder data environment
- Reduces scope
- Applies to merchants and processors

Critical Trap

PCI DSS scope is cardholder data.

Q187: Segmentation Purpose

Question

Why segment networks?

A. Increase speed

B. Limit lateral movement and reduce attack surface

C. Save cost

D. Reduce training

Q187: Explanation

Correct Answer: B

Segmentation limits blast radius:

- Limits spread
- Isolates sensitive systems
- Supports compliance

Critical Trap

Segmentation limits blast radius.

Q188: Data Classification Rules

Question

Who is responsible for classifying data correctly?

A. The custodian

B. The data owner or data steward

C. The auditor

D. The vendor

Q188: Explanation

Correct Answer: B

Owners classify:

- Data owners and stewards classify
- Custodians enforce
- Auditors verify

Critical Trap

Owners classify; custodians enforce.

Q189: Data Loss Prevention Modes

Question

What are common DLP modes?

A. Fast and slow
B. Monitor, block, and quarantine
C. Old and new
D. Red and green

Q189: Explanation

Correct Answer: B

Monitor, block, quarantine:

- Monitor-only mode
- Blocking mode
- Quarantine mode

Critical Trap

DLP modes = monitor, block, quarantine.

Q190: Key Rotation

Question

Why is cryptographic key rotation important?

A. Saves money
B. Limits exposure if a key is compromised
C. Reduces storage
D. Avoids backups

Q190: Explanation

Correct Answer: B

Rotation limits damage:

- Limits blast radius
- Complies with standards
- Better than never rotating

Critical Trap

Regular rotation limits key compromise damage.

Q191: HSM vs KMS

Question

What is the main difference between HSM and KMS?

A. They are the same
B. HSM is dedicated hardware; KMS is software service managing keys
C. KMS is hardware only
D. HSM is software only

Q191: Explanation

Correct Answer: B

HSM hardware; KMS software:

- HSM = dedicated hardware security
- KMS = key management service
- Both protect keys

Critical Trap

HSM is hardware; KMS is often software.

Q192: SSL vs TLS

Question

Which statement is correct about SSL and TLS?

A. They are the same
B. TLS is the successor to SSL and is more secure
C. SSL is newer than TLS
D. TLS is deprecated

Q192: Explanation

Correct Answer: B

TLS supersedes SSL:

- TLS replaced SSL
- SSL is deprecated
- Use modern TLS versions

Critical Trap

TLS supersedes SSL.

Q193: Certificate Pinning

Question

What is certificate pinning?

A. Pinning a certificate to a bulletin board

B. Binding a certificate to an application to prevent MITM attacks

C. Deleting certificates

D. Renewing certificates

Q193: Explanation

Correct Answer: B

Pinning prevents MITM:

- App trusts only specific certs
- Prevents MITM
- Common in mobile apps

Critical Trap

Pinning prevents unauthorized certificates.

Q194: Zero-Day Vulnerability

Question

What is a zero-day vulnerability?

A. A vulnerability patched yesterday
B. A vulnerability unknown to the vendor with no patch available
C. A training gap
D. A configuration error

Q194: Explanation

Correct Answer: B

Zero-day means no patch:

- Unknown to vendor
- No patch
- Requires compensating controls

Critical Trap

Zero-day = no patch yet. Compensate.

Q195: Defense in Depth Example

Question

Which is an example of defense in depth?

A. Only antivirus
B. Firewalls, endpoint protection, MFA, backups, and training
C. Only email filtering
D. Only backups

Q195: Explanation

Correct Answer: B

Multiple independent layers:

- Layers cover different risks
- Reduces single-point failure
- Harder for attackers

Critical Trap

Defense in depth = multiple independent layers.

Q196: Least Privilege Example

Question

Which is a real-world example of least privilege?

A. Giving all staff admin rights
B. Giving support staff read-only access unless escalation is approved
C. Sharing admin passwords
D. Allowing everyone to approve payments

Q196: Explanation

Correct Answer: B

Minimum access required:

- Minimum access required
- Escalation for more access
- Prevents abuse

Critical Trap

Least privilege is minimum access, not maximum.

Q197: Access Review Frequency

Question

How often should access reviews be conducted for critical systems?

A. Every five years

B. At least annually, and more frequently for critical systems

C. Only when someone leaves

D. Never

Q197: Explanation

Correct Answer: B

Annual minimum:

- Annual minimum
- More often for critical systems
- After major changes

Critical Trap

Critical systems need more frequent access reviews.

Q198: Encryption Key Escrow

Question

What is key escrow?

A. Sending keys by email
B. Storing keys with a trusted third party for recovery
C. Deleting keys
D. Sharing keys publicly

Q198: Explanation

Correct Answer: B

Escrow enables recovery:

- Enables recovery
- Used for encryption keys
- Requires strong controls

Critical Trap

Key escrow requires trust and controls.

Q199: Privacy by Default

Question

What does privacy by default mean?

A. All data is public

B. Systems default to the most privacy-protective settings

C. Users must opt out of sharing

D. Ignore privacy

Q199: Explanation

Correct Answer: B

Strictest settings by default:

- Privacy-protective defaults
- Users opt in
- Common in GDPR

Critical Trap

Privacy by default = strictest settings by default.

Q200: Ultimate Security Goal

Question

What is the ultimate goal of information security?

A. Eliminate all attacks

B. Enable business objectives while managing information risk to acceptable levels

C. Maximize tools

D. Increase complexity

Q200: Explanation

Correct Answer: B

Security enables business:

- Security enables business
- Risk is managed to acceptable levels
- Absolute security is impossible

Critical Trap

Security enables business; it is not an end in itself.

Exam Mindset Summary

Remember

- **CIA triad:** Confidentiality, Integrity, Availability
- **IAAA:** Identification, Authentication, Authorization, Accountability
- **Encryption is reversible; hashing is one-way**
- **Signatures** provide integrity, authenticity, non-repudiation – NOT confidentiality
- **Privacy** is about rights; **security** is about protection
- **Zero Trust:** verify every access, no implicit trust
- **Defense in depth:** multiple independent layers
- **Cloud:** shared responsibility; data location matters legally
- **DLP, PAM, SIEM, WAF, HSM:** know what each does and does NOT do

Thank You

Good Luck on Your CRISC Exam!